

CONTAINER: Bounding Credential-Compromise Impact in IEEE 2030.5 DER Systems

Huan Bui*

University of North Carolina at Charlotte, Charlotte, NC, USA

Abstract

IEEE 2030.5 binds a distributed energy resource’s long-lived bootstrap identity to its operational authorization and forbids online certificate revocation. A stolen credential therefore retains control authority indefinitely, and no online mechanism can withdraw it. We present CONTAINER, which replaces the conflated device credential with attested, short-lived, scope-bound operational credentials and uses non-renewal rather than revocation as the containment mechanism, deployable incrementally through native and gateway-proxy tiers. Because reachability alone does not distinguish these designs, we measure impact along four dimensions — cyber reach, state-dependent commandable flexibility, retained authority, and feeder consequence — and give a worked example of two compromises with identical reach but divergent flexibility, persistence, and feeder outcome. We implement a credential service with real X.509 and mutual TLS and a real OpenDSS feeder pipeline. On the IEEE 8500-node feeder, ten implemented security invariants pass, attested issuance costs about 0.23 ms, and a compromise under legacy authorization holds the feeder in violation for the full hour (integrated overvoltage 6956 p.u.-node-min) while CONTAINER’s scope and lifetime enforcement reduce this to 3.8 with recovery at credential expiry. These are reduced-scale pilot results; the pre-registered confirmatory sweep is future work.

*Corresponding author.

Email address: `hbui11@charlotte.edu` (Huan Bui)

Keywords: Critical infrastructure protection, distributed energy resources, IEEE 2030.5, remote attestation, authorization, cyber-physical security

1. Introduction

Distributed energy resources now participate in grid operations at a scale that makes their control interface a systemic concern. IEEE 2030.5 (Smart Energy Profile 2.0), profiled for distribution use by the Common Smart Inverter Profile (CSIP), is the application protocol through which utilities and aggregators dispatch inverter-based resources. An adversary who obtains a credentialed identity in this ecosystem does not merely read data; it can command real and reactive power on physical hardware connected to the grid.

Two properties of the IEEE 2030.5 trust model make this worse than a conventional credential-theft problem. First, the device’s bootstrap identity and its operational authorization are the same long-lived certificate: there is no separate, short-lived operational credential to lose. Second, the standard forbids certificate revocation; it directs that certificate authorities not maintain revocation lists or run status responders, and that clients and servers not check them [1]. A stolen credential is therefore valid until it expires, and its lifetime may be indefinite.

A natural objection is that this is a solved problem: model the DER authorization surface as a privilege graph and measure blast radius as reachability, as a mature line of work does for enterprise networks [2, 3, 4]. We argue this reduction is insufficient as ordinarily applied. What determines the damage of a DER compromise is not only which nodes an adversary can reach, but how much physical capacity those nodes command, how long the adversary retains that capacity, and what the feeder does in response under the grid state at the time. Reachability over a static privilege graph is a function of the attack locus and the graph alone; the quantities that matter are functions of the defensive policy and of exogenous physical state, and neither is topological.

Contributions

- *CONTAINER*, an incrementally deployable credential redesign for IEEE 2030.5 using attested, short-lived, scope-bound operational credentials, with non-renewal as containment and explicit session- and command-effect enforcement, deployable through native and gateway-proxy tiers.
- A *working prototype* — a credential service with real X.509 issuance, mutual TLS, and renewal, plus an OpenDSS feeder pipeline — with ten implemented security invariants verified and containment timing measured.
- A *negative result that constrains the design space*: on the IEEE 8500-node feeder [5], an authorization scope narrow enough to contain a compromise is too narrow to deliver the volt-var service IEEE 1547-2018 mandates and CSIP programs procure. An adversary confined to the *conformant* volt-var envelope still drives the feeder past an IEEE 1547 overvoltage trip threshold. Scope narrowing alone therefore does not contain, and the apparent adequacy of a narrow access list in our earlier configuration was an artifact of an envelope too small to deliver the service at all.
- A *pilot evaluation* with paired per-seed contrasts showing that, at that conformant scope, bounding the *duration* of retained authority is what bounds integrated harm, and quantifying the containment latency this buys: expected retention is the credential lifetime divided by the per-cycle attestation detection probability, not the lifetime itself.

The threat model underpinning all four separates bootstrap identity, operational credential, and authorization scope, and names the baseline standard’s conflation of the first two as the driver of unbounded persistence.

We deliberately do *not* claim the four-dimension accounting of Section 3 as a contribution. Adding resource-by-scope product nodes, a time index, and attached state and policy to a classical attack graph yields that accounting, as Section 4 shows; the separation propositions that follow are true by construction, since a reachability-only measure cannot depend on variables that are not among

its arguments. We keep the notation because the paper needs a vocabulary for "how much, for how long, under which grid conditions", and we keep the worked example because it is a useful illustration. Neither is offered as a theoretical advance. The load-bearing claims of this paper are empirical.

We state scope plainly. The formal model, the separation propositions, and the cyber-side engine are implemented and covered by a regression suite, including the separating counterexample. The credential service and the feeder pipeline are implemented, and we report a pilot evaluation on the IEEE 8500-node feeder, confirmed on the IEEE 123-bus feeder: the results are measured but at reduced scale, two public feeders, one solver, up to ten seeds, on a workstation. The full pre-registered evaluation, with a cross-solver check, constrained hardware, and the full seed budget, is future work.

2. Background and Threat Model

2.1. Authorization in IEEE 2030.5 / CSIP

IEEE 2030.5 uses mutual TLS with X.509 device certificates. A device's identity is the certificate-derived LFDI/SFDI, and its authorization is scoped by a `FunctionSetAssignments` resource that binds it to one or more `DERPrograms`. Physical control authority is carried by the `DERControlBase` control modes: active-power capping (`opModMaxLimW`), signed fixed active power for storage charge and discharge (`opModFixedW`), reactive power (`opModFixedVar`, `opModVoltVar`), volt-watt and frequency-watt curves, and the hard connect and energize controls [6]. The standard specifies certificate-based authentication and function-set scoping; it does not mandate a single canonical access-control object.

2.2. Certificate validity and revocation

The trust model has two properties central to this work [1]. Device certificates have indefinite lifetime, and revocation is prohibited: certificate authorities are directed not to maintain revocation lists or run status responders, and

endpoints are directed not to check them. The stated reasons against online revocation are concrete design constraints, not incidental: field devices have no guaranteed connectivity, a hard-fail check destroys availability while a soft-fail check is trivially bypassed by blocking the responder, revocation presupposes a secure time source that inverters may lack, and no party is defined as responsible for reporting a compromised device. The sanctioned substitute is a local allow or deny list. The consequence for our threat model is direct: once a credential is compromised, there is no online mechanism to withdraw it, so its authority persists until it expires.

2.3. Three separated layers

We separate three layers that the baseline standard conflates. *L1, bootstrap identity*: the hardware-rooted device certificate. *L2, operational credential*: the credential that authorizes live sessions to an aggregator or DER management system. *L3, authorization scope*: the server-side binding from an identity to the function sets it may invoke. In baseline IEEE 2030.5, L1 and L2 are the same long-lived certificate, with no attestation gate and no revocation path. This conflation, not any single cryptographic weakness, is what makes a compromise persist for the certificate lifetime.

2.4. Compromise loci and adversary

We consider four compromise loci of increasing consequence: a single device, an edge gateway, an aggregator or DER management system, and a utility-side issuing role. The adversary obtains a valid credential at one locus (by key extraction, session theft, or a misconfigured or compromised server granting scope) and issues protocol-conformant control commands within that credential’s authorization. The adversary does not break TLS or the underlying cryptography. The utility-side issuing role is the ceiling on what any credential discipline can bound, because it can subvert issuance itself; we treat it as the boundary of the design’s protection rather than a case the design defeats.

2.5. Credential lifecycle and existing containment

The motivation depends on exact certificate-management behavior, which differs across editions: IEEE 2030.5-2018 [7], IEEE 2030.5-2023 [8] (which supersedes it, published December 2024), and the profile in force [9]. We separate four questions the literature tends to conflate: whether a certificate can be cryptographically revoked; whether a server can locally deny an identity despite a valid certificate; whether a device can be re-enrolled or re-keyed; and whether an active session or an already-issued control remains effective after credential expiry. Lack of CRL/OCSP bounds only the first.

The paper’s primary open risk, stated plainly.. **We were unable to obtain IEEE 2030.5-2023.** It is paywalled at roughly US\$255, it is not included in the IEEE GET free-standards programme, and we found no publicly accessible document that quotes its clause text; every free source that quotes 2030.5 quotes the 2018 edition. Our premise — that a device certificate’s lifetime is effectively indefinite while online revocation is unavailable — is therefore evidenced against the 2018 edition and the Sandia analysis [1], not against the edition now in force. We consider this the single largest threat to the paper’s external validity and we do not minimise it. Table 1 states, row by row, exactly what each claim rests on and what would still change if the 2023 text differed. Two rows deserve the reader’s attention before the rest of the paper is read. **S5 is not supported by any source we could access**, and is contradicted in spirit: the Sandia analysis lists dynamic re-provisioning as a *recommendation*, i.e. a capability judged absent, so we treat re-enrollment as something CONTAINERD must supply rather than something the standard already offers. **S8 is the row most exposed to edition drift**, because vendor and reseller descriptions of the 2023 revision state that it eliminates the requirements for mandatory DERControl modes, which is precisely the territory S8 occupies. Where our argument depends on S5 or S8 we say so at the point of use. **[BLOCKER — PI: purchase IEEE 2030.5-2023 (IEEE Xplore doc 10785536, DOI 10.1109/IEEESTD.2024.10785536, approx. US\$255) and confirm S1–S8 clause by clause]**

Table 1: Every standards claim the argument uses, the accessible source of record for it, and what remains unverified. **No row has been checked against IEEE 2030.5-2023**; the edition in force could not be obtained (see text). SAND = Sandia SAND2019-1490 [1]; CSIP = Common Smart Inverter Profile Implementation Guide v2.1 [9]. “Free source” means a document a reader can check without purchase.

ID	Claim	Free source of record	Residual risk
S1	Device certificate lifetime indefinite	SAND §4.1, verbatim	2023 clause unread
S2	CRL use prohibited	SAND §4.1, verbatim	2023 clause unread
S3	OCSP prohibited	SAND §4.1, verbatim	2023 clause unread
S4	Local allow/deny listing available	SAND §4.1, §3.1.1.3; CSIP §5.2.1.4	permitted, not required (SAND §3.1.1.4)
S5	Certificate replacement / re-enrollment possible	none	unsupported ; SAND Rec. 5 implies absent
S6	LFDI/SFDI derives from certificate	SAND §3.1.1.1 and CSIP §5.2.1.2 (independent)	low ; two sources agree
S7	FunctionSetAssignments scopes operations	CSIP §5.2.3.1	clause number only
S8	Scheduled DER controls can persist	CSIP §4.4.2, §6.1.8.2	high ; 2023 reportedly drops mandatory DER-Control modes

2.6. Assets, adversary, and goals

Protected assets: DER control integrity, fleet authorization, operational and attestation keys, and feeder stability and service continuity. *Adversary capabilities*: steals an operational key (and, where tested, a bootstrap key), compromises firmware, steals an active session, compromises a gateway or aggregator, issues protocol-conformant commands, and observes authorized telemetry. *Exclusions*: breaking standard cryptography, physical destruction, and compromising both the root issuer and all audit controls, which we treat as the protection boundary rather than a defended case. *Security goals*: least authority, bounded new-session authority, bounded active-session authority, bounded command-effect duration, fresh-key containment, replay resistance, safe degra-

dation, and auditability. *Non-goals*: defending against malicious root issuance without added governance, detecting every hardware attack, replacing grid protection, and proving safety for every feeder.

3. Impact Accounting: Notation and Motivation

This section fixes notation. It is not offered as a contribution: as Section 4 makes explicit, the accounting below is what one obtains by adding resource-by-scope product nodes, a time index, and attached state and policy to a classical attack graph. We need a vocabulary for “how much, for how long, under which grid conditions”, because the experiments in Section 9 move those three quantities differently, and a single scalar “blast radius” cannot express that. We keep the BR prefix for continuity with prior drafts and call each quantity a dimension.

Substrate.. A static privilege graph $G = (V, E)$ has principals and resources as nodes and access relations as edges. A compromise $x \subseteq V$ is a set of compromised credentials, and a protection policy $\pi = (L, \text{Att}, A)$ encodes a credential-lifetime function L , an attestation-gated renewal predicate Att , and an authorization scope map A . The device and grid operating state at time t is $u_t \in U$ and F is the feeder power-flow and protection model. Neither u_t nor F appears in G , which is the whole point.

The four dimensions.. *Cyber reach* $\text{BR}_{\text{reach}} = \text{ReachSet}(x, \pi)$ is the set of end-points to which the compromised authority can submit an authenticated request, the least fixed point of the π -enabled access relation from x . Reaching a server is not controlling a resource, so we keep it separate from everything below.

Commandable flexibility BR_{flex} is state dependent rather than nameplate. For DER d , $\mathcal{C}_d(t; u_t, A_\pi(d))$ is the set of set-points an adversary holding scope $A_\pi(d)$ can command given irradiance, state of charge, present set-point, and inverter apparent-power and ramp limits. Aggregating over reachable DERs gives achievable intervals $[\Delta P^-, \Delta P^+]$ and $[\Delta Q^-, \Delta Q^+]$; where a scalar is needed we

use $\text{BR}_{\text{flex}} = w_P(\Delta P^+ - \Delta P^-) + w_Q(\Delta Q^+ - \Delta Q^-)$ and state the weights. A read-only scope yields the singleton current set-point, hence zero flexibility.

Retained authority separates three durations that certificate lifetime alone conflates: T_{cred} , until the stolen credential is refused for a *new* session; T_{sess} , until sessions already authenticated with it can no longer issue commands; and T_{cmd} , until queued, scheduled, or latched controls stop affecting the DER. Then

$$\text{BR}_{\text{auth}} = \max(T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}}), \quad \text{BR}_{\text{exp}} = \int \text{BR}_{\text{flex}}(t) \mathbf{1}[\text{authority effective at } t] dt, \quad (1)$$

with BR_{exp} in kW·h or kVar·h. This distinction is the design’s load-bearing one: expiry bounds T_{cred} only, so shortening lifetime without enforcing T_{sess} and T_{cmd} does not bound exposure.

Physical consequence $\text{BR}_{\text{phys}} = \max_{a \in \mathcal{A}} J(F, u, a)$ is the worst outcome reachable within the adversary’s authority, where $\mathcal{A}$ is constrained to authorized functions and device limits. Our primary objective J_V is the voltage-violation area, the node-time outside the ANSI C84.1 band weighted by magnitude. Secondary metrics are maximum per-unit deviation, violating-node count, protection trips, regulator tap operations, energy not served, unnecessary curtailment, and recovery time. We report both an optimizing attacker and an operationally realistic one, so no result is only an omniscient upper bound.

Table 2 gives the types and units. The types differ — a set, a power region, a set of durations, and a physics functional — which is why we do not collapse them into one number.

4. Why Reachability Alone Cannot Rank These Designs

We do not claim that no graph model can represent time or physical impact. Temporal, probabilistic, and attributed cyber-physical attack graphs exist [10, 3, 11] and can encode these quantities. Our claim is only that *static, unweighted* reachability cannot compare DER credential-containment policies, because it omits authorization scope, temporal validity, session and command persistence, state-dependent flexibility, and feeder state.

Table 2: The four impact dimensions. BR_{phys} carries two units depending on whether it is evaluated at one operating point or accumulated over a horizon; both appear in Section 9 and each table states which.

Dim.	Type	Unit	Computation
BR_{reach}	set	count	fixed point of π -enabled access from x
BR_{flex}	interval	kW, kVAr	$\sum_d \mathcal{C}_d(t; u_t, A_\pi(d))$ over reachable DERs
BR_{auth}	duration	s	$\max(T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}})$
BR_{phys}	scalar	<i>snapshot</i> p.u.-node; <i>integrated</i> p.u.-node-min	$\max_a J_V(F, u, a)$ at one operating point, or $\int \max_a J_V dt$ over the horizon

Call a measurement *reachability-only* if it is a function M of the unchanged reachable set $\text{ReachSet}(x)$ alone. Three separations then follow at once. *Scope*: hold the reachable DER set fixed and vary only the scope map A — read-only versus control function sets — and BR_{flex} differs at equal reach. *Time*: an attestation-gated ephemeral credential loses acceptance at the next un-attested renewal while a long-lived unrevoked one does not, so BR_{auth} and BR_{exp} differ at equal initial reach. *Physical state*: at fixed x and π , the same authorized command is harmless at one operating state and drives nodes past an IEEE 1547 overvoltage trip threshold at another, and no privilege graph contains u or F .

These cannot fail, and we present them as definitions rather than findings. M is single-valued in $\text{ReachSet}(x)$, and each construction varies a quantity that is by definition not an argument of M , so the propositions restate that definition. They say which quantities an evaluation must move; they are not evidence that our design moves them. Each ships as a regression test in the released engine so the notation is mechanically checkable. **The evidence for the design is in Section 9, and only there.**

Two points of housekeeping. First, the third construction previously rested on a reverse-power protection trip that the simulator could not represent, there being no protection model at all; Section 7 now implements the IEEE 1547-2018

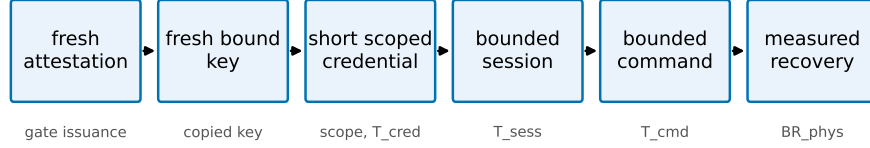


Figure 1: The CONTAINER containment chain. Each link bounds a dimension: attestation gates issuance, fresh-key binding contains a copied key, scope and short lifetime bound BR_{flex} and T_{cred} , session and command enforcement bound T_{sess} and T_{cmd} , and measured recovery bounds BR_{phys} .

Category II overvoltage screen, and Section 9 reports the state dependence as a measured effect — at light load with high PV a given authorized reactive envelope trips in every seed, at normal load in none. Second, an earlier version carried a worked counterexample of two compromises with identical reach but different scope, lifetime, and feeder outcome. It illustrated the notation without separating anything an experiment separates, so we have cut it; the same contrast now appears as measured policy arms in Section 9. Extending a classical attack graph to distinguish such cases requires resource-by-scope product nodes, a time index, and attached u and F — which is precisely the accounting of Section 3. That extension therefore agrees with us, which is why we do not present the accounting as a theoretical advance.

5. CONTAINER Design

CONTAINER separates the layers that IEEE 2030.5 conflates and enforces credential lifetime at the session and command layers, not only at issuance. The design is a containment chain: fresh attestation, a fresh hardware-bound key, a short scoped operational credential, a bounded session, and a bounded command effect, so that removing authority actually removes control. Each link targets a dimension of the model (Fig. 1).

5.1. Components and trust layering

The device keeps a long-lived, hardware-rooted bootstrap identity [12] used only for enrollment and attestation, never accepted directly for DER control. An *attester* produces fresh evidence bound to a freshly generated operational public key; a *verifier* checks evidence against endorsement and reference values and returns an explicit result; a *credential issuer* signs a short-lived operational certificate embedding role, site, scope, and expiry only for a valid attestation result; an *authorization service* maps the operational identity to least-privilege function-set assignments; the *2030.5 server or proxy* authenticates the operational certificate, enforces a maximum session age, and rechecks authorization per command or at a bounded interval; a *session controller* and a *command-lifecycle controller* bound authority beyond expiry; and a *risk controller* selects deny, scope narrowing, or bounded emergency renewal. We use the Entity Attestation Token [13] under the RATS Attester/Verifier/Relying-Party model [14], and define a concrete EAT profile rather than treating EAT as a complete attestation protocol.

5.2. Fresh-key binding

Attesting a device is not sufficient: a healthy device can pass attestation while an attacker retains a previously copied operational key. CONTAINERD therefore requires that every credential epoch use a newly generated operational key, generated in a TPM, TEE, or secure element where available and marked non-exportable, whose public-key digest is carried in the attestation evidence. The issuer signs only the attested public key, refuses renewal that presents only a prior certificate, rejects replayed evidence and reused nonces, and rotates the key even when the device stays healthy. This is what contains a copied key across the next epoch.

5.3. Session and command-effect enforcement

Certificate expiry does not end an open TLS session or an already-issued long-duration control. CONTAINERD closes sessions at credential expiry (or

Table 3: Safe-mode authorization states.

State	Allowed	Denied
Healthy	normal scoped control	out-of-scope control
Verification delayed	read telemetry, hold last safe schedule	new high-impact dispatch
Attestation uncertain	read-only, bounded emergency control	arbitrary set-points
Known compromise	read-only or total denial	all control
Issuer outage	prior low-risk scope, bounded grace	scope expansion, high impact

bounds session age to the credential TTL) and revalidates authorization per command, and it bounds adversary-issued controls through a maximum command duration, cancellation on containment, and safe-default restoration, with explicit handling of scheduled DERControls. The two quantities the prototype measures are

$$\Delta_{\text{expiry}} = t_{\text{last adv. command}} - t_{\text{expiry}}, \quad (2)$$

$$\Delta_{\text{effect}} = t_{\text{effect ends}} - t_{\text{expiry}}, \quad (3)$$

each targeted to zero or a small declared bound. These are exactly the T_{sess} and T_{cmd} components of BR_{auth} .

5.4. Safe-mode policy

Failure behavior is explicit rather than fail-open. The risk controller chooses among the states in Table 3; no failure mode grants indefinite authority, and the safety of each degraded state is validated under feeder conditions rather than assumed.

5.5. Migration compatibility

We separate three compatibility levels, and the protocol requires a passing interoperability test before any of them is claimed, rather than asserting

“backward compatible.” None has yet been tested; Section 9 reports interoperability as untested. *Protocol compatibility*: 2030.5 messages remain standard conformant. *Implementation compatibility*: unmodified client or server software can participate. *Deployment compatibility*: legacy and upgraded devices coexist. Three tiers realize this: a bootstrap-only legacy tier, a gateway-attested proxy tier where an edge gateway holds the operational credential for downstream legacy devices, and a native device-attested tier. We claim only the compatibility level demonstrated by an interoperability test; if only the proxy tier interoperates with an unmodified endpoint, we say CONTAINER supports incremental deployment through a credential-terminating gateway proxy, and no more.

5.6. *What non-renewal inherits from the constraints it cites*

Section 2 adopts the Sandia analysis’s reasons why online revocation fails for DER: no guaranteed connectivity, no trustworthy time on inverters, and no responsible reporting party. Our mechanism inherits two of the three, and we state that rather than let a reader find it.

Secure time. Expiry is a judgment about time, so an endpoint that cannot trust its clock cannot enforce a short lifetime — the deficiency cited against OCSP. An adversary who skews a device clock would extend a “short-lived” credential indefinitely. This is a potential break of the core mechanism, so **expiry is never enforced by the endpoint alone**: the issuer refuses renewal server-side where a trustworthy clock exists; each renewal binds a fresh key to a verifier-supplied nonce, so replaying an attestation cannot extend authority however the clock reads; and session and command limits are monotonic counters, not wall-clock deadlines. A skewed clock then costs availability, not containment. We have not measured skew.

Connectivity. A twelve-hour lifetime means a DER losing backhaul for twelve hours loses control authority, and rural outages of that length are routine. Our availability figures come from in-process fault injection, not networked outages, and renewal storms are untested. An aggregator dropping a fifth of fleet con-

trollability during a verifier outage has created a reliability hazard while closing a security one. Safe-mode degradation to an autonomous volt-var profile exists for this reason; whether that trade is acceptable is an operator’s call.

Who reports compromise. Attestation detects only what it measures. Firmware integrity is measurable; **a stolen operational key on a device with intact firmware passes attestation**. Per-epoch fresh-key binding answers this, but containment latency is then not the lifetime: with per-cycle detection probability p and lifetime T , expected retention is T/p — twelve hours at $T=6\text{ h}$, $p=0.5$, and equal to T only at $p=1$. **We report T/p as the containment-latency figure of merit**. The alternative, a narrow access list on a long-lived credential, contains a copied key only when someone notices and edits the list, which has no bounded latency at all. Bounded beats unbounded; it does not beat instant.

Which tier is deployable. Presenting three tiers evenhandedly is misleading: only one is deployable within the next standards cycle. The native tier needs attestation and a trusted clock on constrained inverter hardware; the legacy tier changes nothing. **The gateway-attested proxy tier resolves all three inheritances at once** — the gateway holds the credential and the clock, attestation runs on capable hardware, downstream devices stay unmodified, and the gateway buffers short outages — and it alone requires no change to already-certified endpoints. We regard it as the deployment path.

5.7. Implementation status

The design is realized as an issuance and renewal service using real X.509 certificates and mutual TLS, with a Python IEEE 2030.5-style client in place of the EPRI C client and structured event logging for every credential, session, and command transition. Its security invariants and workstation overhead are reported in Section 9; a native EPRI-client integration and constrained-hardware measurements remain future work.

6. Cyber-Side Analysis Engine

We implement the cyber-side impact dimensions as an analysis engine, `pkimodel`, that computes BR_{reach} , BR_{flex} , and BR_{auth} for a compromise locus under a policy. The engine models the identity and delegation graph over the six node types of the threat model, with typed issuance, delegation, and authorization edges. Its central modeling choice follows the formalism: a credential’s reach (which DERs it can address) is represented independently of its scope (which function sets it may invoke at each DER). This is what makes the separating counterexample expressible in code, and we ship that counterexample as a regression test: the two compromises resolve to an identical reachable set of eleven DERs, yet the engine computes zero commandable kW for the attested credential against tens of MW for the legacy one, and a persistence of hours against the analysis horizon.

The authorization policy is parameterized, not fixed. A hardcoded permissive access model would overstate what a stolen certificate can command, so the engine exposes four ACL realism levels spanning single-device, site, feeder-segment, and whole-aggregator-fleet scope, and these are varied in the evaluation. On a synthetic 200-device fully-central fleet spread over four feeders, the reachable-DER count grows from one (single-device) to one (site) to fifty (feeder) to two hundred (fleet), and commandable capacity grows in step. The feeder-level figure is the fleet divided by the feeder count, so it moves with that generator parameter; the parameters are released with the artifact. This decomposition operationalizes RQ1: most of the reach gained by a compromise is attributable to authorization scope rather than to authentication alone. The retained-authority dimension is returned as a distribution over duration rather than a point estimate, reflecting the stochastic outcome of attestation-gated renewal, and it separates credential, session, and command-effect components rather than reporting certificate lifetime alone.

The engine consumes synthetic scenarios from a deterministic, seedable generator, since real utility authorization graphs are not public; the generator is

released as part of the artifact. The engine is cyber-side only. It produces the reachable-DER set and the commandable-capacity envelope that the feeder co-simulation consumes to compute BR_{phys} .

7. Feeder Co-Simulation Methodology

The physical consequence dimension is measured by a feeder co-simulation that translates an authorized-control reach from the analysis engine into a malicious dispatch program and runs it on a public distribution feeder. We take the IEEE 8500-node feeder [5] as the primary benchmark and the PNNL 9500-node system [15] as an advanced validation tier. Time-series inputs come from public solar and load datasets. This part of the work is methodologically routine relative to the false-data-injection literature on distribution systems, so we build it to be unimpeachable rather than novel.

Two choices harden the protocol against the standard objections to simulation studies. First, the protocol specifies a GridLAB-D cross-check on the base case and one attack case, following the precedent of the PNNL 9500 report [15]; it is not yet implemented, and any divergence it reveals will be reported rather than suppressed. Second, the full design gates dispatch on credential state through a HELICS federation. The present implementation applies the authorization envelope directly in the OpenDSS driver, which enforces the same constraint without the federation. Of this protocol, the OpenDSS single-solver path is implemented and exercised in Section 9; the HELICS federation and GridLAB-D cross-check are specified here and not yet built. The attack families are volt-var curve distortion, volt-watt curve distortion, export-limit distortion, and curtailment spam. The metrics are the count of nodes violating the ANSI C84.1 bands [16], maximum voltage deviation, the area under the violation curve over time, regulator tap operations, unnecessary curtailment, energy not served, and recovery time to steady limits, with the per-unit voltage excursion as the primary continuous measure and a protection-trip flag as the discrete outcome.

Modelling choices that earlier versions of this work got wrong.. Three are worth stating explicitly, because each changes what the reported numbers mean.

The DER model. The fleet is represented by `OpenDSS PVSystem` objects with an inverter apparent-power rating and an `InvControl` volt-var controller following the IEEE 1547-2018 Category B default characteristic [17]. An earlier version used `Generator` objects at fixed P and Q , which have no inverter model and no curve. Under that model a “volt-var curve distortion” attack was in fact a static setpoint delta, and the attack-family names overstated what was simulated. With a real controller present, curve distortion is now what its name says: the adversary rewrites the characteristic, and the feeder response follows from the controller acting on the distorted curve.

The counterfactual. The base case dispatches PV at its *legitimate scheduled output* under that volt-var curve. An earlier version set every unit to $P=Q=0$, so the counterfactual feeder had no DER at all and the reported ΔJ_V conflated “connect this much generation” with “a credential was stolen” — a condition an interconnection screening study would flag with no adversary present. All ΔJ_V values reported here are measured against legitimate operation. We also report the legitimate base case’s own violation area, so the reader can see how much of the feeder’s stress is attributable to penetration rather than to attack.

Control mode. We solve with `OpenDSS controlmode=static` and we retain it deliberately. This mode does *not* disable the feeder’s controls: on the IEEE 8500 base case at light load it executes 10 regulator tap changes and 6 capacitor switching operations over 15 control iterations, and a full-scope attack drives 12 further tap changes. Controls are disabled only by `controlmode=off`, under which the same attack produces violation area 998.0 and a maximum of 1.3145 p.u. rather than 126.4 and 1.1281 p.u. The feeder’s regulators and capacitor banks are therefore acting against the disturbance in every result we report, and the harm we measure is harm that survives the mitigation a real feeder would apply. We report tap operations alongside every voltage metric so this is visible rather than asserted.

Protection. A protection model is now present, so the trip outcome named

above can actually occur. We screen every node against the IEEE 1547-2018 Category II overvoltage trip thresholds (OV2 at 1.20 p.u. with 0.16 s clearing, OV1 at 1.10 p.u. with 2.0 s clearing) and flag reverse power at the substation. Earlier versions declared a trip metric with no protection model behind it, so the flag could never fire; any claim resting on it was unsupported.

We do not tune feeder parameters to amplify impact; we report what the standard models produce. The clean base case, the four attack families, the eight metrics, and the cross-solver agreement are the acceptance criteria for this component. As with the credential service, a first benchmark run on the IEEE 8500-node feeder appears in the pilot evaluation; the full sweep on both feeders, with the GridLAB-D cross-check and seasonal operating states, follows the pre-registered protocol chosen in advance.

8. Evaluation Protocol (Pre-Registered)

No measured results are reported in this section. We state the evaluation protocol for the confirmatory sweep, and we state precisely what our immutability evidence for it is worth, because a pre-registration that overstates its own guarantee is worse than none.

The scenario matrix and statistical plan are recorded in PREREGISTRATION.md with a SHA-256 content hash recomputable by validate_matrix.py. **That hash is not a timestamp.** It was computed by the same party who could have edited the file, so it shows only that the matrix has not changed since the hash was written; it cannot show *when* the matrix was fixed relative to seeing any outcome. The repository’s version-control anchor does not repair this: the initial commit capturing the pre-registration is dated 2026-07-30, which **postdates every pilot result reported in Section 9**. We therefore make no claim that the design could not have been adjusted after seeing pilot outcomes. It could have been, and no artifact in this repository proves otherwise.

Two consequences follow, and we adopt both. First, the measured results

Table 4: Credential-lifecycle baselines. FK = fresh key per epoch; Sess = session enforcement; Cmd = command-effect cleanup.

ID	Design	Lifetime	Attestation	Scope	FK	Sess	Cmd
B1	legacy identity-as-authority	long	no	deployment ACL	no	no	no
B2	legacy + narrow ACL	long	no	narrow	no	no	no
B3	ephemeral-only	short	no	reference	opt.	expiry	opt.
B4	attestation-only	long	yes	reference	enroll	weak	no
B5	full CONTAINER	short	yes	narrow	per-epoch	yes	yes
B6	CONTAINER safe-mode	short	yes	narrow/degraded	per-epoch	yes	yes

in Section 9 are reported as **exploratory**, not confirmatory, and are excluded from the confirmatory tests. Second, the pre-registration is being deposited on a trusted timestamped repository [**BLOCKER — PI: OSF/Zenodo DOI for pre-registration**], whose independently issued timestamp will support the immutability claim *from the deposit date forward* — that is, for the confirmatory sweep specified below, and not retroactively for the pilots.

Baselines and mechanism ablations.. Six credential-lifecycle designs are compared: legacy identity-as-authority (B1), legacy with a narrow access list (B2), ephemeral-only (B3), attestation-only (B4), full CONTAINER (B5), and safe-mode renewal (B6). Each baseline is specified by explicit fresh-key, session-enforcement, and command-cleanup attributes, because the central claim is that short lifetime alone does not contain a copied key, an active session, or a persistent command. Eight mechanism ablations (A1–A8) each remove one link of the containment chain, so the measured reduction is attributed to a mechanism rather than to shorter certificates. Table 4 gives the baseline mechanism attributes.

Factors and design.. The factors are credential time to live, authorization scope, compromise locus (with the issuer treated as a trust boundary, not a defended case), DER penetration and technology mix, attack program, attestation-trust state, renewal policy, and operating state. Every attack runs under both a worst-case optimizing attacker and an operationally realistic telemetry-limited

attacker, so no result is only an omniscient upper bound. The primary comparison is the fully-crossed lifetime-by-scope factorial, whose interaction term is the compositional claim.

Statistics.. The experimental unit is the complete paired scenario run, not the per-timestep sample. The primary voltage-violation area is analyzed with a mixed-effects model, $\log(1 + Y) = \beta_0 + \beta_1 \log(\text{TTL}) + \beta_2 \text{Scope} + \beta_3 \log(\text{TTL}) \times \text{Scope} + b_{\text{day}} + b_{\text{seed}} + \epsilon$, with the interaction coefficient testing the primary hypothesis and robust, aligned-rank, or permutation fallbacks where assumptions fail. Protection trips use mixed-effects logistic regression, violating-node counts a negative-binomial mixed model, and recovery time survival analysis. Effect sizes are the median paired difference, the ratio of geometric means, the paired rank-biserial correlation, and odds ratios, each with bootstrap confidence intervals, and Holm correction is applied within, not across, hypothesis families. A five-seed pilot and a simulation-based power analysis set the production seed count before final comparisons are viewed. These inferential procedures apply to the confirmatory sweep, not to the pilot in Section 9: the stored pilot data support medians and interquartile ranges over seeds, which is what that section reports, but they do not support the mixed-effects estimates, bootstrap intervals, or family-corrected p -values specified here, and none are claimed.

Pre-registered hypotheses and honesty rule.. The primary hypothesis is a non-additive lifetime-by-scope interaction on voltage-violation area. Secondary hypotheses cover capacity-time exposure reduction, the advantage of the full design over both the ephemeral-only and attestation-only ablations, the reduction of post-expiry residual authority by session and command enforcement, locus dominance, the safe-mode availability tradeoff, fresh-key containment of a copied key, and the renewal-latency safety margin. The full design must reduce capacity-time exposure and voltage-violation area on at least one public feeder, which is the study’s go/no-go gate. The expected-pattern statement records what we anticipate; any deviation, including a weak physical effect on a robust feeder,

is reported rather than engineered away, and severe or nonconverging runs are never silently dropped.

9. Pilot Evaluation

We report a pilot evaluation that exercises the full pipeline end to end and produces measured results. Its scope is deliberately limited and stated plainly: a workstation platform (no constrained hardware), the real IEEE 8500-node feeder [5] as a first benchmark run but not yet the PNNL 9500 system, a single solver (OpenDSS, no GridLAB-D cross-check), load-state snapshots rather than a full seasonal time series, one PV penetration level, a fixed rather than per-state-optimized attacker, and a Python IEEE 2030.5-style client in place of the EPRI C client. These results establish that the mechanism and the measurement work; the pre-registered full-scale sweep is not replaced by them. The cyber-side engine, credential service, OpenDSS feeder pipeline, and availability fault injection are implemented and measured; native EPRI-client traffic, constrained-hardware attestation, the GridLAB-D cross-check, the HELICS federation, interoperability tests, and the full pre-registered sweep are not.

Throughout, the primary physical endpoint is the *induced overvoltage area* ΔJ_V : the attack-case value of the one-sided overvoltage term of J_V , summed over all energized nodes as $\sum_i \max(0, V_i - 1.05)$, minus its value in the base case at the same load state. Positive values mean the attack pushed nodes above the ANSI C84.1 upper band [16]; values at or below zero mean it did not. A single power-flow solution therefore yields ΔJ_V in per-unit nodes (p.u.-node), and the time-series experiment reports the same quantity integrated over a one-minute time step, in per-unit node-minutes (p.u.-node-min). We label each table and figure with the unit it carries.

Functional invariants and containment (C1, C2). The credential service uses real X.509 / ECDSA certificates and an EAT-style attestation token. Ten implemented security invariants all pass on the prototype: bootstrap identity cannot authorize control, issuance requires a valid fresh attestation, the certificate is

Table 5: Security invariants implemented by the prototype (real X.509/mTLS). All ten pass. The identifiers emitted in `results/credsvc.json` are now identical to the IDs below; an earlier release numbered them I1–I5 and I7–I11, skipping I6, and the artifact has been renumbered to remove that discrepancy.

ID	Invariant	Result
I1	Bootstrap identity cannot authorize control	pass
I2	Issuance requires a fresh attestation	pass
I3	Credential bound to a fresh public key	pass
I4	Replayed evidence rejected	pass
I5	Expired credential cannot issue a command	pass
I6	Scope enforced per command	pass
I7	Bad measurement yields degraded/denied scope	pass
I8	Prior epoch cannot self-renew	pass
I9	Copied prior key fails after rotation	pass
I10	Active session/command bounded past expiry	pass

bound to a freshly generated operational key, replayed evidence is rejected, an expired credential cannot issue commands, per-command scope matches issuance, a bad measurement yields only a narrowed safe-mode scope, a prior epoch cannot self-renew, and a copied prior operational key is contained at the next epoch. With per-command revalidation the post-expiry acceptance gap is $\Delta_{\text{expiry}} = -0.5\text{s}$ (the last accepted adversarial command precedes expiry), against $+5.0\text{s}$ without enforcement, where it grows to the cached session age. A fresh operational key is generated each epoch, so a copied key is useless after rotation. Table 5 lists the invariants, the identifier each carries in the released result file, and their outcomes. These are the invariants the prototype implements and tests; they are not a proof of the design, and properties outside this set are untested.

Overhead (C3). On the workstation tier, over 500 iterations, median software-path latencies are 0.03 ms for key generation, 0.06 ms for attestation construction, 0.23 ms for a full attested issuance, and 2.3 ms for a real mutual-TLS hand-

shake, and the issuer sustains about 4900 renewals per second single-threaded. Renewal is therefore inexpensive here. These are standard EC P-256 primitives dominated by one ECDSA signature and verification, so constrained-controller cost can be estimated from public-key throughput; a hardware-backed measurement is future work. These are software-path timings, not deployment latencies.

Availability (C6). The renewal safety margin $T_{\text{TTL}} - (T_{\text{renew,p99}} + T_{\text{net}})$ stays positive at every tested lifetime down to five minutes and a 100,000-device fleet re-mints in about 20s, so short lifetimes are latency-feasible. The risk is instead a verifier outage longer than the lifetime. Injecting verifier outages, fail-closed denial retains 0.77 of legitimate control availability, a bounded grace period 0.83, and degraded-scope safe mode 1.0. The injection is in-process; networked outages, clock skew, and renewal storms remain.

Time-series containment and mechanism decomposition (C5). The central physical result measures temporal containment directly, rather than as a product of a measured and a modeled factor. We run each policy as one time-series on the real IEEE 8500-node feeder: a compromised credential drives the DER from minute five, and its lifecycle then determines whether the malicious set-point keeps affecting the feeder. We integrate the real induced overvoltage area over a 60-minute horizon, in p.u.-node-minutes, across three seeds (Fig. 2); values below are medians over those three runs. A legacy credential (B1) holds the feeder in violation for the whole horizon (integral 6956, no recovery). Holding the broad scope fixed but adding the CONTAINER lifecycle (A4) halves the integral to 3196 and the feeder recovers at credential expiry, which isolates the temporal effect of lifetime with session and command enforcement at equal scope. Removing session enforcement (A2) or command cleanup (A3) from that configuration returns the feeder to no recovery (7030), so each mechanism is necessary. Narrowing scope (B5) additionally bounds the instantaneous envelope, and the integral falls to 3.8. This single experiment gives the equal-scope decomposition the design intends: scope bounds the envelope, lifetime with enforcement bounds the duration, and neither alone suffices. Three seeds on one

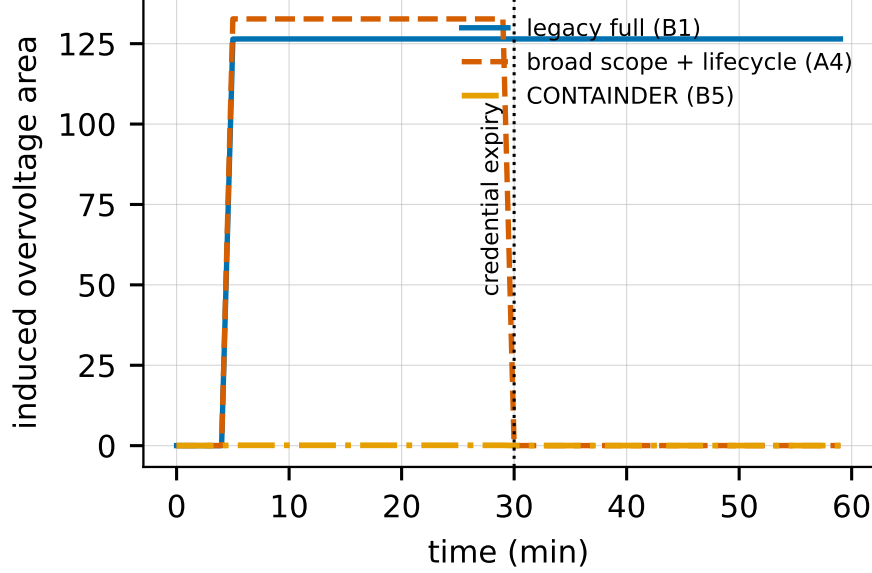


Figure 2: Time-series induced overvoltage area (p.u.-node-min) on the IEEE 8500-node feeder (light load; one representative seed of $n=3$; medians in the text are over all three). A legacy credential (B1) never recovers; at the same broad scope the CONTAINER lifecycle (A4) recovers at credential expiry; narrow scope (B5) additionally bounds the instantaneous envelope. The session-off and command-cleanup-off ablations track B1 and are omitted for clarity.

feeder at one operating state cannot establish an effect size; the confirmatory sweep is what tests this pattern.

Feeder consequence across operating states (C5).. We run an export/overvoltage attack on the real IEEE 8500-node feeder (4876 buses, 8531 nodes, 1177 loads, 10.8 MW aggregate load at nominal multiplier) with 600 seeded rooftop-PV units of 12 kW each (7.2 MW), ten paired seeds, under three load states. Because the 8500 base has native undervoltage at its extremities, we report the induced *overvoltage* area the attack targets rather than a two-sided area that would credit the attack for lifting sagging nodes; this attack-specific endpoint was chosen after observing the base undervoltage, while the two-sided area remains the declared primary system-level endpoint. Throughout, ΔJ_V is measured

against *legitimate scheduled PV operation under an IEEE 1547-2018 Category B volt-var curve*, not against a feeder with no DER.

How narrow must scope be before it stops containing? (C5). This is the only question an operator actually needs answered, and fixing two envelopes by fiat cannot answer it. We therefore sweep the authorized envelope continuously along the two axes an IEEE 2030.5 `FunctionSetAssignments` narrowing can act on, at five paired seeds and two operating states, and locate the breach threshold (Table 6).

On the *active-power* axis, where the adversary holds `DERControl`, there is a genuine threshold. Under light load, ΔJ_V stays negative up to $\sigma=0.7$ of nameplate and turns positive between $\sigma=0.7$ and $\sigma=0.8$; the IEEE 1547 overvoltage trip screen fires in 60% of seeds at $\sigma=0.7$ and in every seed from $\sigma=0.8$. Restricting active-power authority below roughly 70% of nameplate does contain.

On the *reactive* axis it does not, and this is the paper’s most consequential result. Confining the adversary to the volt-var function set — the narrowest scope that still delivers the service IEEE 1547-2018 requires and CSIP volt-var programs procure — **breaches at every envelope we tested, including an envelope of zero.** At the full Category B capability of 5.28 kvar (44% of nameplate) the median induced area is 87.9 (per-seed range 79.9–100.8, all five seeds tripping OV1 at ≥ 1.10 p.u., $v_{\max}$ up to 1.142). At 0 kvar it is still 31.2, with every seed tripping. The mechanism at zero is worth stating plainly: an adversary authorized only to configure volt-var need not inject anything: it is enough to *suppress* the reactive absorption the feeder was relying on, which is squarely inside a volt-var-only authorization. **There is therefore no reactive envelope that both contains a compromise and delivers the volt-var service.**

This overturns the reading in an earlier version of this work. That version placed “narrow” at 0.6 kvar, which is 5% of a 12 kW unit’s nameplate and only 11.4% of the Category B range, and reported that it held the feeder inside the ANSI band. It does not deliver volt-var at that envelope, so the containment it

appeared to show was the containment of authorizing almost nothing. Measured against legitimate operation rather than against an empty feeder, even that envelope breaches ($\Delta J_V = 17.4$, trips in 4/5 seeds). We accordingly withdraw the claim that narrow scope “retains the most common legitimate DER function while bounding the attack”: at the tested envelope it did not retain the function, and at the conformant envelope it does not bound the attack.

Consequence is strongly state dependent. Under normal load the same sweep produces $\Delta J_V \leq 12.0$ on the active axis and ≤ 11.4 on the reactive axis, with no trips at any envelope. Light load with high PV is the binding state, as the physical-state dependence of Section 4 anticipates.

Why ΔJ_V is negative at small envelopes.. The negative entries on the active axis are not noise and not reactive “support”. Against a legitimate counterfactual in which PV generates at its full scheduled output, an adversary restricted to $\sigma < 0.7$ of nameplate is *curtailing* relative to that schedule: it injects less active power than legitimate operation would, so the voltage rise along the feeder falls and the one-sided overvoltage area shrinks. A restrictive active-power scope therefore turns the compromise into an unwanted-curtailment problem — an availability and revenue harm our voltage endpoint does not price — rather than an overvoltage problem. An earlier version of this work attributed such negative values to a narrowed reactive envelope “marginally supporting” voltage, which is backwards: voltage support raises voltage and would *increase* a one-sided overvoltage area. The correct mechanisms are curtailment relative to schedule on the active axis and reactive *absorption* on the reactive axis.

This attack is loud, and that matters.. At the full-scope light-load condition, 6710 of 8531 energized nodes (79%) sit above 1.05 p.u. with a maximum of 1.128 p.u. That is not a stealthy manipulation; it is a feeder-wide excursion that AMI voltage reporting, regulator operation counts, and customer complaints would surface within a single metering interval. Two conclusions follow. First, it weakens any narrative in which such a compromise quietly persists for the two-year lifetime of a certificate: an adversary behaving this way is found

Table 6: Scope-envelope sweep on the IEEE 8500-node feeder: median induced overvoltage area ΔJ_V (p.u.-node) against legitimate volt-var operation, and the fraction of seeds in which the IEEE 1547 Category II overvoltage trip screen fires. Five paired seeds per cell. The reactive axis holds active power at its legitimate schedule and varies only the authorized reactive envelope.

Authorized envelope	light load / high PV		normal	
	ΔJ_V	trip	ΔJ_V	trip
<i>Active-power axis</i> ($\sigma \times$ nameplate, DERControl)				
$\sigma = 0.0$	-56.0	0.00	-0.07	0.00
$\sigma = 0.5$	-30.3	0.00	-0.33	0.00
$\sigma = 0.7$	-1.3	0.60	0.17	0.00
$\sigma = 0.8$	22.1	1.00	1.49	0.00
$\sigma = 1.0$	63.1	1.00	11.98	0.00
<i>Reactive axis</i> (volt-var scope; legitimate P retained)				
0 kvar (suppress volt-var)	31.2	1.00	2.01	0.00
0.6 kvar (earlier “narrow”, 11% of 1547)	17.4	0.80	1.38	0.00
2.4 kvar (45% of 1547)	49.9	1.00	5.58	0.00
5.28 kvar (full IEEE 1547 Cat B)	87.9	1.00	11.44	0.00

quickly, and the operative containment latency becomes the utility’s detection-and-response time rather than the credential lifetime. Second, and more usefully, it identifies the attacker our evaluation does *not* cover. An adversary who holds voltages just inside the ANSI band, or who acts only during the minutes of peak PV, would extract far more value from long persistence precisely because nothing alarms — and that is exactly the case in which credential lifetime, rather than detection, is the binding constraint. Our pre-registered protocol specifies an operationally realistic telemetry-limited attacker alongside the oracle worst case; the stealth-constrained variant is the more important of the two for this paper’s thesis, and it is not yet run. We regard this as the most significant gap in the present evaluation.

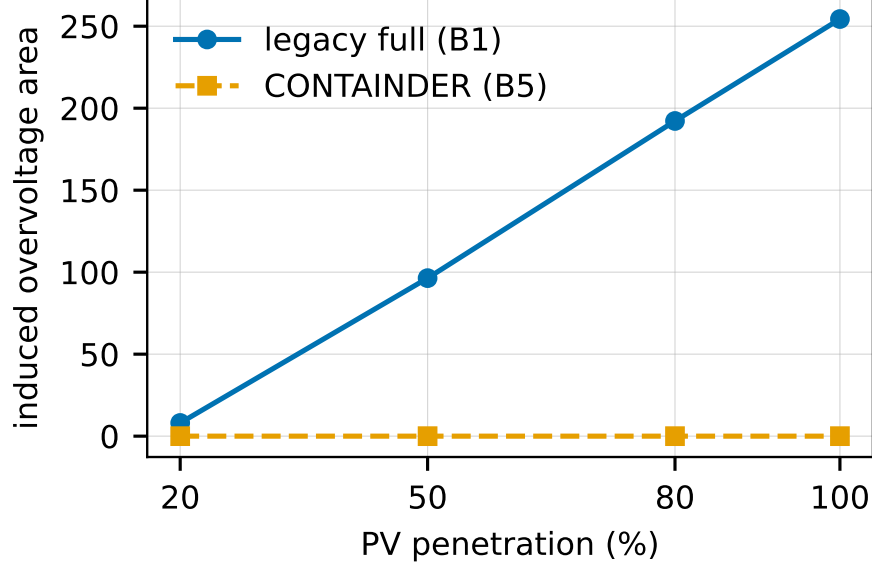


Figure 3: Induced overvoltage area (p.u.-node, snapshot) versus PV penetration (IEEE 8500, light load, $n=5$ seeds). Harm scales with penetration under the legacy baseline; containment is penetration-independent under CONTAINER at the tested levels.

Results measured under the superseded scope configuration.. Three further sweeps were run before the scope-envelope result above, using the earlier 0.6 kvar “narrow” envelope and the zero-DER counterfactual. We report them, and we mark plainly what they do and do not now support. Under a legacy full-authorization compromise, induced overvoltage grows with PV penetration from 8 at 20% to 254 at 100% (five seeds, Fig. 3); it is reachable through active or reactive authority alike, with areas of 122 (export-limit), 97 (volt-var), and 57 (volt-watt) across attack families (five seeds, Fig. 4); and it appears on a second public feeder, the IEEE 123-bus system, at up to 2.2 under high penetration (three seeds), though that stiffer regulated 4.16 kV feeder needs more penetration to breach the band. **These legacy-baseline measurements stand.** What does *not* stand is the accompanying claim, made in an earlier version, that the narrowed scope held induced overvoltage at or near zero in every one of these

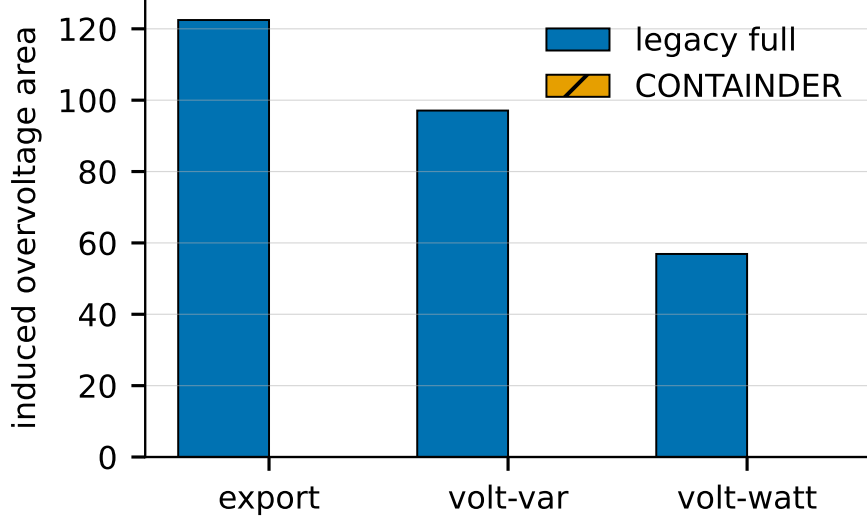


Figure 4: Induced overvoltage area (p.u.-node, snapshot) by attack family (IEEE 8500, light load, $n=5$ seeds). Narrowing scope contains overvoltage driven by active or reactive authority.

cells, and that it therefore “retains the most common legitimate DER function while bounding the attack”. That envelope is 11.4% of the IEEE 1547 Category B reactive range and does not deliver volt-var, and the near-zero readings were taken against a counterfactual feeder carrying no DER. Table 6 supersedes them. We have not re-run the penetration, attack-family, or IEEE 123 sweeps at the conformant envelope, so the conformant-scope result is established at one penetration level, on one feeder, in the two operating states of Table 6.

Modeled retained authority, and what it is not evidence for (H2).. An earlier version of this work summarised the baselines with a proxy $E_{\text{phys}} = \Delta J_V \times \text{BR}_{\text{auth}}$ and reported that moving from ephemeral to legacy persistence “multiplies light-load exposure roughly 1700×”. **We withdraw that figure.** The two cells share the same authorization scope and therefore the same measured ΔJ_V of 126.60, so that factor cancels exactly and the ratio reduces to $17524/10 = 1752.4$, a quotient of two assumed lifetimes. It contains no measurement whatsoever, and presenting it as an evaluation result was wrong. The

only defensible statement is the tautology that a credential assumed to last two years is assumed to be held about 1750 times longer than one assumed to last ten hours. The direct, measured replacement for that claim is the time-series contrast above.

We also rename the quantity. It is E_{phys} , a physical-consequence-times-duration product in p.u.-node-hours, and it is *not* the flexibility-time BR_{exp} of Section 3, which carries kW·h and kVAr·h. The two were previously distinguished in prose while sharing a name. This paragraph belongs to hypothesis H2 (capacity-time exposure); an earlier version labelled it H1, which the pre-registration reserves for the lifetime-by-scope interaction on voltage-violation area.

Two entries in Table 7 contradict the narrative that earlier version drew from it, and we now say so directly.

First, **B5’s retained authority (12.22 h) is longer than B3’s (10.0 h)**. On that dimension the full design is strictly worse than ephemeral-only. The cause is not an error: B3’s credential simply expires and is never renewed, whereas B5’s is attestation-gated and *does* renew, surviving a $\text{Geometric}(p)$ number of cycles until attestation catches the compromise. With $T=6$ h and $p=0.5$ the expectation is $T/p = 12$ h, which is what the model returns (and at $p=1$ it returns exactly 6 h). Renewal is what makes CONTAINER deployable — an un-renewed credential strands the legitimate device too — and its price is that containment latency is governed by detection probability, not by lifetime. This is the T/p figure of merit of Section 5, and it means B5’s advantage over B3 comes from scope, not from time.

Second, **B2 and B5 both sit at ≈ 0 in this table, and we no longer read that as support for the design**. It is the arithmetic consequence of a “narrow” scope whose measured ΔJ_V was 0.0 exactly: any lifetime multiplied by zero is zero. Once scope is set at the conformant envelope of Table 6, the physical factor is not zero and the tie disappears. **We therefore withdraw the sentence “neither half alone suffices” as it was argued from this table**, since the comparison it invoked — B5 against B3 and B4 — excluded

Table 7: Modeled retained authority BR_{auth} and the exposure product $E_{\text{phys}} = \Delta J_V \times BR_{\text{auth}}$ in p.u.-node-hours (light load, IEEE 8500, $n=10$ seeds). ΔJ_V is measured; BR_{auth} is a *model output* under assumed lifetime and detection parameters, not a measurement, so every product in the last column inherits that assumption. The ≈ 0 entries reflect a non-conformant narrow envelope whose measured ΔJ_V was zero; see Table 6.

Baseline	Scope	BR_{auth} (modeled)	E_{phys}
B1 legacy full	full	$\sim 2 \text{ yr}$	2.2×10^6
B2 ACL-narrow	narrow (non-conformant)	$\sim 2 \text{ yr}$	≈ 0
B3 ephemeral-only	full	10.0 h	1.3×10^3
B4 attestation-only	reference	$\sim 14 \text{ d}$	8.3×10^3
B5 full CONTAINERD	narrow (non-conformant)	12.22 h	≈ 0
B6 safe-mode	narrow (non-conformant)	12.22 h	≈ 0

the one baseline that tied B5. The claim is re-established, on different and measured grounds, by the time-series contrast at conformant scope reported above: there, scope alone does not contain, which is what makes duration enforcement necessary.

Seed inventory. Table 8 is the complete inventory of every measured run behind this section, so that no experiment’s scale has to be inferred from prose.

Limitations. These results are pilot results and we do not generalize them. Physical results come from two public feeders and a single OpenDSS solver, with no GridLAB-D cross-check and a fixed export attacker; Table 8 gives the full seed inventory.

The IEEE 9500 failure mode, stated. The PNNL 9500-node system was obtained but did not converge in our build, and we name the mode rather than leaving it an unexplained absence. The failure is in the *base case*, with no attack applied and no PV of ours placed: running the model’s own shipped driver unaltered — which sets the voltage bases, calls `calcv`, and solves at `maxiter=1000 maxcontroliter=100` — returns `Converged = False` with an empty error description, and every bus per-unit magnitude reads zero, i.e. the

Table 8: Complete inventory of measured runs. Seeds are paired across policy arms within an experiment. “Arms” counts the policy or envelope conditions evaluated at each seed.

Experiment	Seeds	Arms	States
IEEE 8500 snapshot sweep	10	2	3
IEEE 8500 time series (corrected)	20	9	2
Scope-envelope sweep	5	21	2
PV penetration sweep	5	1	1
Attack-family sweep	5	4	1
Legitimate-utility run	3	3	1
IEEE 123 confirmatory run	3	2	1
Credential-service invariants (C1)	1	10	—
Overhead microbenchmarks (C3)	500 iterations	4	—
Availability fault injection (C6)	3 policies	3	—

solution collapses rather than merely missing tolerance. It reproduces at 1000 iterations, under both the normal and Newton algorithms, and with feeder controls both enabled (`controlmode=static`) and disabled (`controlmode=off`), so it is neither a control-loop oscillation nor an iteration-budget shortfall. Our build is DSS C-API 0.14.5 / DSS-Python 0.15.7 / OpenDSSDirect.py 0.9.4 on macOS arm64. **We did not resolve it and we do not attribute it:** we cannot exclude a platform or build defect on our side rather than a defect in the model, and we did not have a second OpenDSS build available to discriminate. It is deferred to an appendix tier per the pre-registered contingency. The consequence for this paper is that the cross-feeder generality of these results rests on the IEEE 123 confirmatory run alone, which is weak, and we do not claim more. Retained-authority figures, and the exposure proxy built on them, are model outputs under assumed attestation and lifetime parameters, not measured field values. Overhead is workstation-only: there is no constrained-hardware or TEE measurement. The availability result injects verifier outages in-process rather than as networked or hardware failures, and clock skew and renewal storms are untested. Incremental deployment is by construction; inter-

operability against an unmodified IEEE 2030.5 endpoint is untested, and the exact clause-level delta between the 2018 and 2023 editions of the standard’s certificate-management text remains open pending access to the revised standard. CONTAINER bounds physical consequence under the evaluated scope configurations; the pre-registered sweep on two public feeders, with a cross-solver check, seasonal states, constrained hardware, and the full seed budget, is what would support quantitative claims beyond these.

10. Related Work

We position CONTAINER against ten strands (Table 9).

IEEE 2030.5 and CSIP security. The 2018 and 2023 editions of IEEE 2030.5 mandate mutual TLS with X.509 device certificates [7, 8], constrained for interconnection by the Common Smart Inverter Profile [9]. The closest prior work is the 2030.5 security tutorial of Passos et al. [6], a survey that proposes no redesign, quantifies no feeder consequence, and formalizes no impact metric; Qi et al. survey the broader DER and smart-inverter surface [18]. The Sandia analysis supplies the revocation constraints we respect [1].

DER and smart-inverter attacks. High-wattage IoT botnets can move the grid [19, 20]; on the DER side, inverter attacks destabilize grid and market [21] and distribution voltage control is attackable under high PV [22], while the SUN:DOWN disclosure catalogs fleet-scale inverter vulnerabilities [23]. We tie the attack surface to the credential lifecycle rather than assuming device compromise.

Distribution-grid cyber-physical impact. False-data-injection work quantifies compromise consequence [24, 25, 26], grounded by the 2015 Ukraine incident [27] and quantitative risk formulations [28]; our feeder method is supporting, not novel.

Short-lived certificates and PKI lifecycle. ACME [29] and Let’s Encrypt [30] automate issuance, SCEP [31] is the incumbent device enrollment, and HTTPS-ecosystem measurement quantifies the lifecycle problem [32]; we adopt short

lifetimes as one link of a chain.

Hardware-bound identity. Secure device identity [12], firmware TPM [33], and hardware DICE [34] root our bootstrap layer.

Remote attestation. We use the RATS architecture [14], the Entity Attestation Token [13], and BRSKI [35], on established principles [36], adding fresh-key binding.

Attack-graph and cyber-physical metrics. Logic-based [2, 37, 38], probabilistic and Bayesian [3, 11, 10], and k -zero-day [4] metrics are static-snapshot and cyber-only; Section IV shows what reachability-only reading omits, positioning our model as complementary.

Co-simulation. HELICS federates the cyber and grid models [39, 40] with GridLAB-D on the power side [41].

DER authorization. IEEE 1547 [17] defines the DER functions, DERMS perform feeder voltage management [42], and role-based access control [43] abstracts the scoping we narrow and enforce.

Revocation at scale. Web-PKI revocation delivery is gap-ridden [44], scalable revocation remains an open problem [45, 46], and even OCSP Must-Staple adoption is weak [47], which motivates containment by short-lived credentials rather than by revocation.

Workload identity: the closest existing system. SPIFFE and its SPIRE runtime [48, 49] implement almost exactly the chain we describe. SPIRE attests node and workload, issues short-lived scope-bound X.509 SVIDs keyed to the attested identity, refuses renewal when attestation fails, and relies on expiry rather than revocation; recent work extends it to IoT fleets [50] and nested tokens [51]. We must therefore answer whether CONTAINER is workload identity with a DER label. Two differences are load-bearing. First, SPIFFE has no notion of a *physical effect that outlives the credential*: revoking a workload identity stops a process opening new connections, but does not retract a volt-var curve already written into an inverter or a schedule already accepted for tomorrow. Our T_{sess} and T_{cmd} enforcement exists because actuation persists in a way computation does not. Second, scope binds to `FunctionSetAssignments`, whose conformant

settings are dictated by IEEE 1547-2018 [17] and CSIP [9] rather than chosen freely — and our central negative result is that this externally fixed envelope is too wide to contain, which has no analogue where the deployer picks the scope. The field constraints of Section 5 differ too.

The Web PKI has already adopted non-renewal. Our mechanism is not speculative, and we should not present it as though it were. The CA/Browser Forum defined a Short-lived Subscriber Certificate in 2023 and *exempted it from CRL and OCSP status checking* [52], which is precisely “non-renewal replaces revocation”, already ratified; Baseline Requirements v2.2.8 sets that threshold at seven days [53]. Ballot SC-081v3, approved in April 2025, phases the maximum TLS certificate validity from 398 days down to 47 days by 2029 [54]. This is simultaneously the strongest external validation of our premise — the largest deployed PKI reached the same conclusion independently — and the sharpest limit on our novelty. We claim no novelty for short-lived credentials or for expiry-based containment. What we claim is the mapping onto DER authorization: which scope object to bind, what the conformant scope envelope costs, and that session and command-effect enforcement are separately necessary because grid actuation persists.

DER guidance and competing key management. IEEE 1547.3-2023 is the cybersecurity guide for interconnected DER [55] and the natural home for these recommendations; NISTIR 7628 [56] and IEC 62443 [57, 58] give the enclosing frameworks; NREL’s DER certification line [59, 60] and gap analysis [61] document the certification landscape. IEC 62351 is the sharpest comparison: Part 8 gives role-based access control [62] and Part 9 specifies key management *including* enrollment and revocation for power-system equipment [63]. Part 9 is a directly competing answer, and the honest question is why 2030.5/CSIP does not adopt it. Not technical superiority on our side: 62351-9’s revocation machinery assumes the connectivity and responsible-reporting party the Sandia analysis [1] found absent, and CSIP deployments certify against the 2030.5 profile. Where an operator has that connectivity, 62351-9 is a reasonable alternative, and we say so rather than claim the field.

Table 9: Positioning against representative prior work. y = yes, n = no, p = partial, - = n/a.

Work	2030.5	Scope	Time	Phys.	Attest.	Proto.	Feeder
Attack-graph metrics [2, 3, 4]	n	p	n	n	n	-	n
2030.5 security survey [6]	y	p	n	n	n	n	n
Attestation building blocks [14, 13, 12]	n	p	p	p	y	p	n
CONTAINERD (this work)	y	y	y	y	y	p*	p*

y = addressed; p = partial; n = not addressed; - = not applicable. *Partial: a prototype and a pilot feeder evaluation are reported in Section 9; native-client interoperability, constrained hardware, and the full pre-registered sweep are not yet done.

11. Ethics and Responsible Disclosure

This work studies the consequences of credential compromise in order to bound them, and it carries a corresponding responsibility. All experiments use synthetic and lab-generated certificates. We use no real vendor keys or secrets, we test against no production DER fleet or any internet-reachable device, and we build no exploit tooling bound to a specific vendor product. The malicious dispatch programs exist only inside the feeder co-simulation and are never emitted to hardware.

The physical-consequence results describe what a compromised but protocol-conformant credential can already do under the deployed standard; they do not introduce a new vulnerability so much as measure an existing exposure that the standard’s prohibition on revocation leaves unmitigated. The redesign and its migration path are offered as the constructive counterpart to the measurement: the point of quantifying the blast radius is to shrink it.

Disclosure and release, reconciled.. These two commitments are one timeline, not two. Nothing in this work identifies a vulnerability in a specific vendor product; what it identifies is a property of a published standard, which the standards body and the Sandia analysis [1] already describe in public. There is

accordingly no embargoed finding whose disclosure must precede release. The artifact — code, result files, and pre-registration — is deposited and citable at the time of publication, which is the same event as public release. Should the confirmatory sweep identify a concrete weakness in a specific implementation, we will notify that implementer and the relevant standards body first and delay only the affected component of the release; the remainder is not held back.

12. Limitations and Conclusion

Limitations.. The boundaries of the evaluation are stated once, next to the results they bound, at the end of Section 9: two public feeders and a single solver, modeled rather than measured retained authority, workstation-only overhead, in-process availability injection, untested interoperability, and the open clause-level delta between the 2018 and 2023 editions of the standard. Two further boundaries are proper to the model rather than to the measurements. The authorization graphs used by the engine are synthetic, because real utility authorization graphs are not public; we mitigate this with a released, parameterized generator and by treating access-model permissiveness as an ablated variable rather than a fixed assumption. And our claims about revocation rest on the primary Sandia analysis rather than on a clause-level reading of the revised standard.

Conclusion.. Credential compromise in IEEE 2030.5 is not well described by how many nodes an adversary can reach. It is described by how much physical capacity those nodes command, how long the adversary keeps it, and what the feeder does in response. We formalized these as four impact dimensions, showed that reachability-only measurement omits scope, time, and feeder state, and built a redesign that shrinks them using attested, short-lived, scope-bound operational credentials with non-renewal as containment. A pilot end-to-end evaluation is consistent with the design: the ten implemented security invariants pass, per-command enforcement contains authority at expiry, and at the light- and normal-load states where a legacy credential drives the feeder outside the

ANSI band, narrowing scope keeps the overvoltage a compromise induces on the IEEE 8500-node feeder within it, with the full evaluation still to come. The model is the lever: it says which quantities a DER-authorization defense must move, and it rejects the measures that only move reach.

Data availability

The analysis engine, the X.509/mutual-TLS credential service, the OpenDSS feeder experiment scripts, the pre-registration document, and every result file underlying the numbers reported here are deposited as a single archive with a persistent identifier [**BLOCKER — PI: Zenodo DOI for code + result JSONs + pre-registration**] and are cited as reference [64]. The IEEE 8500-node and IEEE 123-bus test feeders are publicly available from the referenced OpenDSS distributions. The one input we cannot redistribute is the IEEE 2030.5-2023 standard text itself, which is sold by IEEE; Section 2 states precisely which claims depend on it and which edition each was checked against.

Funding

This research received no specific grant from any funding agency in the public, commercial, or not-for-profit sectors.

Declaration of competing interest

The author declares that he has no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

CRedit authorship contribution statement

Huan Bui: Conceptualization, Methodology, Software, Validation, Formal analysis, Investigation, Data curation, Writing – original draft, Writing – review and editing, Visualization.

Declaration of generative AI and AI-assisted technologies in the writing process

During the preparation of this work the author used a large language model to assist with copy editing, LaTeX table formatting, and the drafting of code comments in the released artifact. After using this tool the author reviewed and edited the content as needed and takes full responsibility for the content of the published article. No generative AI tool was used to produce, analyse, or interpret any experimental result, and no text generated by such a tool was incorporated without verification against the underlying data.

References

- [1] J. Obert, P. Cordeiro, J. Johnson, G. Lum, T. Tansy, M. Pala, R. Ih, Recommendations for trust and encryption in DER interoperability standards, Tech. Rep. SAND2019-1490, Sandia National Laboratories, Albuquerque, NM (Feb. 2019).
- [2] X. Ou, S. Govindavajhala, A. W. Appel, MulVAL: A logic-based network security analyzer, in: 14th USENIX Security Symposium (USENIX Security 05), USENIX Association, 2005.
- [3] L. Wang, T. Islam, T. Long, A. Singhal, S. Jajodia, An attack graph-based probabilistic security metric, in: Data and Applications Security XXII (DBSec 2008), Vol. 5094 of Lecture Notes in Computer Science, Springer, 2008, pp. 283–296. doi:10.1007/978-3-540-70567-3_22.
- [4] L. Wang, S. Jajodia, A. Singhal, P. Cheng, S. Noel, k-zero day safety: A network security metric for measuring the risk of unknown vulnerabilities, IEEE Transactions on Dependable and Secure Computing 11 (1) (2014) 30–44. doi:10.1109/TDSC.2013.24.
- [5] R. F. Arritt, R. C. Dugan, The IEEE 8500-node test feeder, in: IEEE PES T&D 2010, IEEE, 2010, pp. 1–6. doi:10.1109/TDC.2010.5484381.

- [6] D. Passos, C. de Sousa, R. C. Gomes, D. F. de Assis, F. G. d. O. Passos, C. Albuquerque, A tutorial and security overview on the IEEE 2030.5-2018 standard, *IEEE Communications Surveys & Tutorials* 27 (6) (2025) 3615–3640. doi:10.1109/COMST.2025.3532110.
- [7] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, iEEE Standards Association (2018). doi:10.1109/IEEESTD.2018.8608044.
- [8] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, iEEE Standards Association; published Dec. 2024 (2023). doi:10.1109/IEEESTD.2024.10785536.
- [9] SunSpec Alliance, Common Smart Inverter Profile (CSIP): IEEE 2030.5 Implementation Guide for Smart Inverters, version 2.1 Edition, released 16 March 2018; supports CA Rule 21 Phase 2 (Mar. 2018).
- [10] N. Poolsappasit, R. Dewri, I. Ray, Dynamic security risk management using bayesian attack graphs, *IEEE Transactions on Dependable and Secure Computing* 9 (1) (2012) 61–74. doi:10.1109/TDSC.2011.34.
- [11] M. Frigault, L. Wang, Measuring network security using bayesian network-based attack graphs, in: 2008 32nd Annual IEEE International Computer Software and Applications Conference (COMPSAC), IEEE, 2008, pp. 698–703. doi:10.1109/COMPSAC.2008.88.
- [12] IEEE, IEEE Standard for Local and Metropolitan Area Networks—Secure Device Identity (2018). doi:10.1109/IEEESTD.2018.8423794.
- [13] L. Lundblade, G. Mandyam, J. O’Donoghue, C. Wallace, The entity attestation token (EAT), RFC 9711, Internet Engineering Task Force (IETF) (Apr. 2025). doi:10.17487/RFC9711.
- [14] H. Birkholz, D. Thaler, M. Richardson, N. Smith, W. Pan, Remote ATtestation procedures (RATS) architecture, RFC 9334, Internet Engineering Task Force (IETF) (Jan. 2023). doi:10.17487/RFC9334.

- [15] A. Anderson, S. Vadari, J. Barr, S. Poudel, A. Dubey, T. McDermott, R. Podmore, Introducing the 9500 node distribution test system to support advanced power applications: An operations-focused approach, Tech. Rep. PNNL-33471, Pacific Northwest National Laboratory (PNNL), u.S. DOE Office of Scientific and Technical Information (2022). doi:10.2172/1922914.
- [16] National Electrical Manufacturers Association (NEMA), American National Standard for Electric Power Systems and Equipment—Voltage Ratings (60 Hz), revision of ANSI C84.1-2016; reaffirmed 2025 (2020).
- [17] IEEE, IEEE Standard for Interconnection and Interoperability of Distributed Energy Resources with Associated Electric Power Systems Interfaces (2018). doi:10.1109/IEEESTD.2018.8332112.
- [18] J. Qi, A. Hahn, X. Lu, J. Wang, C.-C. Liu, Cybersecurity for distributed energy resources and smart inverters, *IET Cyber-Physical Systems: Theory & Applications* 1 (1) (2016) 28–39. doi:10.1049/iet-cps.2016.0018.
- [19] S. Soltan, P. Mittal, H. V. Poor, BlackIoT: IoT botnet of high wattage devices can disrupt the power grid, in: 27th USENIX Security Symposium (USENIX Security 18), USENIX Association, 2018, pp. 15–32.
- [20] T. Shekari, A. A. Cárdenas, R. Beyah, MaDIoT 2.0: Modern high-wattage IoT botnet attacks and defenses, in: 31st USENIX Security Symposium (USENIX Security 22), USENIX Association, 2022, pp. 3539–3556.
- [21] X. Hui, S. Karumba, S. C.-K. Chau, M. Ahmed, Destabilizing power grid and energy market by cyberattacks on smart inverters, in: Proceedings of the 16th ACM International Conference on Future and Sustainable Energy Systems (e-Energy '25), ACM, 2025, pp. 136–151. doi:10.1145/3679240.3734613.
- [22] Y. Isozaki, S. Yoshizawa, Y. Fujimoto, H. Ishii, I. Ono, T. Onoda, Y. Hayashi, Detection of cyber attacks against voltage control in distri-

- bution power grids with PVs, *IEEE Transactions on Smart Grid* 7 (4) (2016) 1824–1835. doi:10.1109/TSG.2015.2427380.
- [23] Forescout Vedere Labs, SUN:DOWN: Destabilizing the grid via orchestrated exploitation of solar power systems, Vulnerability research report, Forescout Technologies, industry (non-peer-reviewed) report; landing page titled “SUN:DOWN Vulnerability Research Report.” 46 CVEs across Sun-grow, Growatt, SMA (Mar. 2025).
- [24] Y. Liu, P. Ning, M. K. Reiter, False data injection attacks against state estimation in electric power grids, in: *Proceedings of the 16th ACM Conference on Computer and Communications Security (CCS ’09)*, ACM, 2009, pp. 21–32. doi:10.1145/1653662.1653666.
- [25] R. Deng, G. Xiao, R. Lu, H. Liang, A. V. Vasilakos, False data injection on state estimation in power systems—attacks, impacts, and defense: A survey, *IEEE Transactions on Industrial Informatics* 13 (2) (2017) 411–423. doi:10.1109/TII.2016.2614396.
- [26] G. Liang, J. Zhao, F. Luo, S. R. Weller, Z. Y. Dong, A review of false data injection attacks against modern power systems, *IEEE Transactions on Smart Grid* 8 (4) (2017) 1630–1638. doi:10.1109/TSG.2015.2495133.
- [27] G. Liang, S. R. Weller, J. Zhao, F. Luo, Z. Y. Dong, The 2015 Ukraine blackout: Implications for false data injection attacks, *IEEE Transactions on Power Systems* 32 (4) (2017) 3317–3318. doi:10.1109/TPWRS.2016.2631891.
- [28] A. Teixeira, K. C. Sou, H. Sandberg, K. H. Johansson, Secure control systems: A quantitative risk management approach, *IEEE Control Systems Magazine* 35 (1) (2015) 24–45. doi:10.1109/MCS.2014.2364709.
- [29] R. Barnes, J. Hoffman-Andrews, D. McCarney, J. Kasten, Automatic certificate management environment (ACME), RFC 8555, Internet Engineering Task Force (IETF) (Mar. 2019). doi:10.17487/RFC8555.

- [30] J. Aas, R. Barnes, B. Case, Z. Durumeric, P. Eckersley, A. Flores-López, J. A. Halderman, J. Hoffman-Andrews, J. Kasten, E. Rescorla, S. Schoen, B. Warren, Let’s encrypt: An automated certificate authority to encrypt the entire web, in: Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS ’19), ACM, 2019, pp. 2473–2487. doi:10.1145/3319535.3363192.
- [31] P. Gutmann, Simple certificate enrolment protocol (SCEP), RFC 8894, Internet Engineering Task Force (IETF) (Sep. 2020). doi:10.17487/RFC8894.
- [32] Z. Durumeric, J. Kasten, M. Bailey, J. A. Halderman, Analysis of the HTTPS certificate ecosystem, in: Proceedings of the 2013 Internet Measurement Conference (IMC ’13), ACM, 2013, pp. 291–304. doi:10.1145/2504730.2504755.
- [33] H. Raj, S. Saroiu, A. Wolman, R. Aigner, J. Cox, P. England, C. Fener, K. Kinshumann, J. Löser, D. Mattoon, M. Nyström, D. Robinson, R. Spiger, S. Thom, D. Wooten, fTPM: A software-only implementation of a TPM chip, in: 25th USENIX Security Symposium (USENIX Security 16), USENIX Association, 2016, pp. 841–856.
- [34] L. Jäger, R. Petri, DICE harder: A hardware implementation of the device identifier composition engine, in: Proceedings of the 15th International Conference on Availability, Reliability and Security (ARES ’20), ACM, 2020, pp. 1–8. doi:10.1145/3407023.3407028.
- [35] M. Pritikin, M. Richardson, T. Eckert, M. Behringer, K. Watsen, Bootstrapping remote secure key infrastructure (BRSKI), RFC 8995, Internet Engineering Task Force (IETF) (May 2021). doi:10.17487/RFC8995.
- [36] G. Coker, J. Guttman, P. Loscocco, A. Herzog, J. Millen, B. O’Hanlon, J. Ramsdell, A. Segall, J. Sheehy, B. Sniffen, Principles of remote attestation, International Journal of Information Security 10 (2) (2011) 63–81. doi:10.1007/s10207-011-0124-7.

- [37] P. Ammann, D. Wijesekera, S. Kaushik, Scalable, graph-based network vulnerability analysis, in: *Proceedings of the 9th ACM Conference on Computer and Communications Security (CCS '02)*, ACM, 2002, pp. 217–224. doi:10.1145/586110.586140.
- [38] S. Jajodia, S. Noel, B. O'Berry, Topological analysis of network attack vulnerability, in: *Managing Cyber Threats: Issues, Approaches, and Challenges*, Vol. 5 of *Massive Computing*, Springer, 2005, pp. 247–266. doi:10.1007/0-387-24230-9_9.
- [39] T. D. Hardy, B. Palmintier, P. L. Top, D. Krishnamurthy, J. C. Fuller, HELICS: A co-simulation framework for scalable multi-domain modeling and analysis, *IEEE Access* 12 (2024) 24325–24347. doi:10.1109/ACCESS.2024.3363615.
- [40] B. Palmintier, D. Krishnamurthy, P. Top, S. Smith, J. Daily, J. Fuller, Design of the HELICS high-performance transmission-distribution-communication-market co-simulation framework, in: *2017 Workshop on Modeling and Simulation of Cyber-Physical Energy Systems (MSCPES)*, IEEE, 2017, pp. 1–6. doi:10.1109/MSCPES.2017.8064542.
- [41] D. P. Chassin, K. Schneider, C. Gerkensmeyer, GridLAB-D: An open-source power systems modeling and simulation environment, in: *2008 IEEE/PES Transmission and Distribution Conference and Exposition*, IEEE, 2008, pp. 1–5. doi:10.1109/TDC.2008.4517260.
- [42] I. Rahman, N. Selak, E. Paaso, Distributed energy resource management system (DERMS) solution for feeder voltage management for utility integrated DERs, in: *2021 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT)*, IEEE, 2021, pp. 1–5. doi:10.1109/ISGT49243.2021.9372281.
- [43] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, C. E. Youman, Role-based access control models, *Computer* 29 (2) (1996) 38–47. doi:10.1109/2.485845.

- [44] Y. Liu, W. Tome, L. Zhang, D. Choffnes, D. Levin, B. Maggs, A. Mislove, A. Schulman, C. Wilson, An end-to-end measurement of certificate revocation in the web’s PKI, in: Proceedings of the 2015 Internet Measurement Conference (IMC ’15), ACM, 2015, pp. 183–196. doi:10.1145/2815675.2815685.
- [45] J. Larisch, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, C. Wilson, CRLite: A scalable system for pushing all TLS revocations to all browsers, in: 2017 IEEE Symposium on Security and Privacy (SP), IEEE, 2017, pp. 539–556. doi:10.1109/SP.2017.17.
- [46] T. Smith, L. Dickinson, K. Seamons, Let’s revoke: Scalable global certificate revocation, in: Proceedings 2020 Network and Distributed System Security Symposium (NDSS), Internet Society, 2020. doi:10.14722/ndss.2020.24084.
- [47] T. Chung, J. Lok, B. Chandrasekaran, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, J. Rula, N. Sullivan, C. Wilson, Is the web ready for OCSP must-staple?, in: Proceedings of the Internet Measurement Conference 2018 (IMC ’18), ACM, 2018, pp. 105–118. doi:10.1145/3278532.3278543.
- [48] The SPIFFE specification: Secure production identity framework for everyone, <https://github.com/spiffe/spiffe>, specification set: SPIFFE ID and Verifiable Identity Document, SPIFFE Workload API, SPIFFE Workload Endpoint, X.509-SVID, JWT-SVID.
URL <https://github.com/spiffe/spiffe>
- [49] SPIFFE: Secure production identity framework for everyone, Cloud Native Computing Foundation graduated project, accepted to CNCF 2018-03-29; incubating 2020-06-22; graduated 2022-08-23 (2022).
URL <https://www.cncf.io/projects/spiffe/>
- [50] D. Bakoyiannis, G. Kornaros, O. Tomoutzoglou, M. D. Grammatikakis, M. Coppola, Trusting IoT devices at scale in the computing continuum

- through SPIFFE/SPIRE certificates, in: ApplePies, 2025, pp. 279–285. doi:10.1007/978-3-032-17174-0_40.
- [51] H. Z. Cochak, C. C. Miers, P. H. B. Correia, M. A. Marques, M. A. S. Jr., Lightweight SPIFFE verifiable identity document (LSVID): A nested token approach for enhanced security and flexibility in SPIFFE, in: CloudCom, 2024, pp. 9–16. doi:10.1109/CLOUDCOM62794.2024.00015.
- [52] CA/Browser Forum, Ballot SC063v4: Make OCSP optional, require CRLs, and incentivize automation, passed; voting period 2023-07-06 to 2023-07-13; introduced the Short-lived Subscriber Certificate into Baseline Requirements v2.0.0 (Jul. 2023).
URL <https://cabforum.org/2023/07/14/ballot-sc063v4-make-ocsp-optional-require-crls-and-incentivize-automation/>
- [53] CA/Browser Forum, Baseline requirements for the issuance and management of publicly-trusted TLS server certificates, short-lived Subscriber Certificate defined in Section 1.6.1; validity periods in Section 6.3.2; 47-day maximum effective 2029-03-15 (2026).
URL <https://cabforum.org/working-groups/server/baseline-requirements/requirements/>
- [54] CA/Browser Forum, Ballot SC081v3: Introduce schedule of reducing validity and data reuse periods, approved; voting period 2025-04-04 to 2025-04-11 (Apr. 2025).
URL <https://cabforum.org/2025/04/11/ballot-sc081v3-introduce-schedule-of-reducing-validity-and-data-reuse-periods/>
- [55] IEEE, IEEE guide for cybersecurity of distributed energy resources interconnected with electric power systems, Tech. Rep. IEEE Std 1547.3-2023, Institute of Electrical and Electronics Engineers, iEEE Xplore document 10352402 (Dec. 2023). doi:10.1109/IEEESTD.2023.10352402.
- [56] The Smart Grid Interoperability Panel–Smart Grid Cybersecurity Committee, Guidelines for smart grid cybersecurity, Tech. Rep. NISTIR 7628

Revision 1, National Institute of Standards and Technology, Gaithersburg, MD (Sep. 2014). doi:10.6028/NIST.IR.7628r1.

- [57] IEC, Industrial communication networks – network and system security – part 3-3: System security requirements and security levels, Tech. Rep. IEC 62443-3-3:2013, International Electrotechnical Commission (Aug. 2013).
URL <https://webstore.iec.ch/en/publication/7033>
- [58] IEC, Security for industrial automation and control systems – part 4-2: Technical security requirements for IACS components, Tech. Rep. IEC 62443-4-2:2019, International Electrotechnical Commission (Feb. 2019).
URL <https://webstore.iec.ch/en/publication/34421>
- [59] W. Hupp, D. Saleem, J. T. Peterson, K. Boyce, Cybersecurity certification recommendations for interconnected grid edge devices and inverter based resources, Tech. Rep. NREL/TP-5R00-80581, National Renewable Energy Laboratory, Golden, CO (Nov. 2021). doi:10.2172/1832209.
- [60] D. Saleem, M. Slowinske, Cybersecurity certification standard for distributed energy and inverter based resources, Tech. Rep. NREL/PR-5R00-81827, National Renewable Energy Laboratory, Golden, CO, conference presentation; OSTI 1842981 (Jan. 2022).
URL <https://www.osti.gov/biblio/1842981>
- [61] C. MaGill, D. Saleem, J. Waggoner, J. deCastro, DER cybersecurity standards: Assessment and gap analysis, Tech. Rep. NLR/TP-5T00-93100, National Laboratory of the Rockies, Golden, CO (2026). doi:10.2172/3015061.
- [62] IEC, Power systems management and associated information exchange – data and communications security – part 8: Role-based access control for power system management, Tech. Rep. IEC 62351-8:2020, International Electrotechnical Commission (Apr. 2020).
URL <https://webstore.iec.ch/en/publication/61822>

- [63] IEC, Power systems management and associated information exchange – data and communications security – part 9: Cyber security key management for power system equipment, Tech. Rep. IEC 62351-9:2023, International Electrotechnical Commission, second edition; cancels and replaces IEC 62351-9:2017 (Jun. 2023).
URL <https://webstore.iec.ch/en/publication/66864>
- [64] H. Bui, [dataset] CONTAINER: analysis engine, attested credential service, OpenDSS feeder pipeline, pre-registration, and result files, Zenodo, dOI pending deposit (2026).